

摘要：

Anthropic因Mythos模型过于危险拒绝发布，引发华尔街与监管层震动。专家指出，AI令漏洞披露到武器化的窗口期从771天骤降至不足4小时，代理AI的自动化攻击使沿用数十年的“负责任披露”机制名存实亡。Mythos真正的威胁直指医院、小型零售商等防御薄弱环节。

网络安全领域赖以运转的时间缓冲正在消失。彭博观点专栏作家Parmy Olson指出，从软件漏洞公开披露到可用攻击工具出现，这一窗口期已从2018年的平均771天骤降至如今不足4小时。Anthropic最新AI模型Mythos的出现，正将这场危机推至公众视野中央——而其真正的警示，并非专门针对大型银行，而是对防御薄弱的广大中小机构发出的紧急信号。

Anthropic将Mythos定性为“危险到无法发布”，此举迅速引发连锁反应。美国财政部长Scott Bessent随即召集华尔街高管评估系统防御准备；目前，财政部正寻求直接获取Mythos访问权限。率先获准接触该模型的英国AI安全研究院（UK AI Security Institute）经评估认为，Mythos在发动复杂网络攻击方面的能力，确实超越OpenAI的ChatGPT和谷歌的Gemini等现有工具。

然而，英国AI安全研究院同时指出，Mythos对“防御薄弱”或架构简单的系统构成的威胁最大。大型银行拥有全球顶级的IT安全体系，真正暴露在高风险之中的，是更为广泛的中小企业、医院及小型零售商——这些机构既是黑客历来惯常瞄准的目标，也普遍缺乏快速响应所需的资源与能力。

随着代理AI（agentic AI）的崛起，漏洞从公开披露到遭到利用之间的窗口期实际上已经消失。Olson认为，这迫使整个行业直面一个尚无答案的根本问题：当漏洞在数小时内即可被武器化，沿用数十年的“负责任披露”机制是否仍然合理，数周乃至数月的补丁部署流程是否还具有实际意义？

大银行不是最脆弱的一环

Anthropic发布Mythos的方式，率先将外界目光引向了金融业。Olson指出，Scott Bessent的出手，令这家AI公司在IPO前夕获得了罕见的公众关注度，同时也引发外界对谁能获得Mythos独家访问权限的质疑。

英国AI安全研究院的评估结论，给部分市场担忧提供了依据——Mythos的确比其他AI工具更擅长发动复杂网络攻击。但该研究院同时强调，其威胁主要集中于防御薄弱的目标。大型银行拥有全球最为严密的IT防御体系，黑客群体历来倾向于绕开这类目标。

真正面临严峻考验的，是大量缺乏充分防御的中小机构。黑客通常不直接攻击银行，而是扫描互联网，锁定可以实施勒索软件攻击的医院，或防线薄弱的小型商户。AI能力的提升，使这些机构的处境愈加岌岌可危。

从771天到不足4小时：AI压缩了窗口期

理解为何AI的崛起如此危险，需要先厘清此前网络安全的运转逻辑。Olson解释，技术行业长期奉行“负责任披露”原则：一旦软件缺陷被发现，厂商会向公众公布并附上修复建议，给客户留出打补丁的时间。微软的“补丁星期二”（Patch Tuesday）即是典型——这一机制每月定期披露Office 365、Windows等产品中发现的安全漏洞。

Barclays、Wells Fargo等银行的IT团队，在收到补丁建议后须经历兼容性测试、管理层审批、最终部署等多个环节，整个流程通常历时数周乃至数月。在生成式AI出现之前，这一节奏尚可接受，因为黑客研究并利用已披露漏洞所需的时间，通常比受害方完成修复更长。

但AI已彻底改变了这一等式。即便在两年前，黑客就可以将漏洞披露详情粘贴进ChatGPT，指令其扫描GitHub等公开代码库，寻找相似的可利用模式。例如，若微软披露了Office 365处理某类文件的缺陷，聊天机器人不仅能建议具体利用路径，还能迅速找出Outlook、Teams等产品中的类似弱点。据zerodayclock.com数据，软件漏洞从公开到可用攻击工具构建完成的平均时间，已从2018年的771天压缩至今天的不足4小时。

代理AI：漏洞利用走向全自动化

Olson认为，近几个月AI能力的最新跃升，使威胁进入了一个更为危险的新阶段。AI公司陆续赋予模型“代理”能力，使其能够自主执行操作，而不仅仅提供建议。Anthropic于今年1月发布的Claude Cowork，已具备自动发送邮件、管理日历等独立操作能力。

对于网络攻击者而言，这意味着AI工具不再仅仅是寻找漏洞的助手，而是会自动尝试不同突破路径，直到某种方法奏效。Mythos更进一步，能够将多个漏洞“链式”串联，组成多步骤复合攻击——这一能力此前仅属于顶尖人类黑客。Olson以入室盗窃作比喻：找到第一扇开着的窗，借此从内部解开门锁，再关闭警报系统；每一步单独看都不足以得手，但串联起来便可长驱直入。

即便在代理AI普及之前，生成式AI已在悄然重塑黑客的工具箱：聊天机器人被用于优化钓鱼邮件，使其更具迷惑性；实时虚拟人生成器制造深度伪造视频通话，令受害者难辨真伪。代理AI的出现，则进一步将“黑客行为本身”推向自动化，而非仅仅充当辅助工具。

"负责任披露"的逻辑正在瓦解

Olson直接质疑了网络安全行业长期奉行的核心原则。Anthropic披露Mythos，固然有助于其在IPO前塑造技术神秘感，但Olson指出，这一事件客观上迫使整个行业面对一个久被回避的结构性问题：当漏洞披露与遭到利用之间的时间窗口实际上已经消失，“负责任披露”机制的底层逻辑还能否成立？数周乃至数月的补丁部署流程，是否已成为无用之功？

对于大型银行而言，这一问题至少尚有解题路径。Olson认为，大型银行至少拥有足够的人员储备和资金，能够着手探索并逐步实现近实时的补丁部署。

真正悬而未决的，是那些需要以同样速度行动、却远未具备相应能力的中小企业。它们所需要的，既有技术层面的支撑，也有监管框架的介入——而这两者，市场目前均无法提供。

风险提示及免责条款

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

限时权益申领

* 体验资格每人限申领一次

VIP会员·7天畅读卡 | 大师课·入门串讲

扫码
免费领取



限免

34 收藏

分享到:



写评论

请发表您的评论



表情



图片

发布评论

